

## Cyber Risk Governance Roadmap (Phased Implementation)

DPMPTSP – A Practical and Incremental Improvement Plan

### 1. Roadmap Objective

This roadmap provides a phased and realistic plan to strengthen cyber risk governance at DPMPTSP. It is developed based on the current (AS-IS) condition and focuses on incremental improvements that can be implemented within the public sector environment, taking into account limited resources.

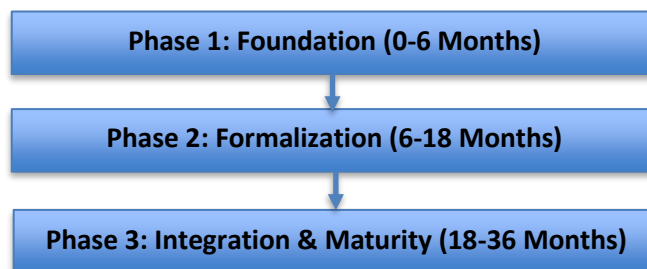
### 2. Guiding Principles

The following principles form the foundation for developing this roadmap, ensuring that improvements to cyber risk governance are realistic, gradual, and aligned with DPMPTSP's current conditions and capacity:

- Starting from existing practices and strengthening them incrementally.
- Prioritizing governance, roles, and documentation before technical controls.
- Avoiding excessive bureaucracy or the use of complex tools.
- Aligning improvements with the principles of ISO/IEC 27005, ISO/IEC 27001, and NIST SP 800-39.

### 3. Cyber Risk Governance Roadmap

A phased Cyber Risk Governance Roadmap was developed to provide a structured and realistic approach to improving governance practices within DPMPTSP. The roadmap is designed to reflect the organisation's current constraints while enabling incremental and sustainable maturity development.



*Figure1. Cyber Risk Improvement Roadmap*

Figure 1 presents the Cyber Risk Governance Roadmap, illustrating the three phased approach to governance improvement within the organisation. The diagram provides a high-level overview of the progression from foundational governance practices to more structured and integrated mechanisms.

The detailed explanation of each phase is provided in the following subsections, where Phase 1 focuses on establishing foundational capabilities, Phase 2 on formalising processes, and Phase 3 on integrating governance into organisational decision-making and continuous improvement.

### **3.1 Phase 1: Foundation (0–6 Months)**

Objective: Establish a basic structure, visibility, and accountability for cyber risk governance.

To achieve this objective, the following initial steps are defined as practical actions that can be implemented immediately in accordance with DPMPTSP's current condition:

- Appointing a role or responsible party to coordinate cyber risk and IT-related matters.
- Using a Governance Checklist to document the current state.
- Developing an initial qualitative Cyber Risk Register (5–10 key risks).
- Socializing the Incident Handling and Escalation Flow to relevant stakeholders.
- Initiating simple incident recording (date, system, impact).

### **3.2 Phase 2: Formalization (6–18 Months)**

Objective: Formalize recurring processes and improve consistency across the organization.

At this stage, the focus is on developing and implementing documented processes so that cyber risk management practices can be carried out more consistently and sustainably across all units:

- Developing a basic cyber security policy approved by management.
- Establishing and documenting simple cyber risk assessment procedures.
- Conducting regular cyber security awareness training (at least annually).
- Periodically reviewing and updating the Cyber Risk Register.
- Implementing basic reporting of cyber risks and incidents to management.

### **3.3 Phase 3: Integration and Maturity (18–36 Months)**

Objective: Integrate cyber risk governance into overall organizational governance and planning.

At this stage, the organization begins to strengthen its governance approach by ensuring that cyber risk management is directly linked to organizational planning, decision-making, and performance evaluation processes. The focus is on cross-functional alignment, strengthening evaluation mechanisms, and gradually improving maturity in a sustainable manner through the following actions:

- Aligning cyber risk governance with SPBE initiatives and coordination with Diskominfo.
- Implementing regular governance reviews and simple internal audits.
- Enhancing incident management processes and learning from incidents.
- Developing simple metrics and indicators for cyber risk and security awareness.
- Gradually considering alignment with ISO/IEC 27001 requirements.

#### **4. Expected Benefits**

The following benefits are expected to be achieved through the phased implementation of this roadmap, alongside increased structure, clarity, and consistency in cyber risk governance at DPMPTSP:

- Improved visibility of cyber risks and clearer accountability.
- Reduced reliance on informal and ad-hoc practices.
- Improved readiness to respond to incidents and service disruptions.
- Continuous improvement of governance maturity.

#### **5. Closing**

This roadmap emphasizes a practical and sustainable approach. DPMPTSP can incrementally enhance its cyber risk governance without creating excessive operational or administrative burdens.